

作品编号： （必须填写系统自动分配的编号）

作品类别： ☒ 软件设计 ☐ 硬件制作 ☐ 工程实践
☐ 密码应用技术 ☐ 其它



2025 年第十届全国密码技术竞赛作品设计报告

作品题目：基于行为口令与国密 SM4 的智能保密文件库（BehVault）

2026 年 6 月 7 日

中国密码学会

基本信息表
编号:
作品题目: 基于行为口令与国密 SM4 的智能保密文件库 (BehVault)
作品类别: ☒ 软件设计 ☐ 硬件制作 ☐ 工程实践 ☐ 密码技术应用 ☐ 其它
作品内容摘要: 随着数字化办公的普及, 文件安全面临密码泄露、凭证窃取、内部人员越权访问等严峻挑战。传统密码认证仅验证"你知道什么", 无法判断"你是谁"。本文提出 BehVault——基于行为口令与国密 SM4 的智能保密文件库, 将击键动力学 (Keystroke Dynamics) 行为生物特征与国密 SM4 分组密码算法有机融合, 构建"密码+行为+加密"三层纵深防护体系。 用户在注册阶段输入固定密码 10 次, 系统采集每次按键的 Hold Time 和 Flight Time, 提取 10 维击键特征向量, 构建个性化行为模板。登录时, 系统同步验证密码正确性与行为特征匹配度, 采用 K 近邻 (KNN, K=5) 算法计算归一化欧氏距离, 通过自校准距离-风险映射机制输出 0~100 连续风险评分。SM4 国密算法模块完整自实现 S 盒、线性变换、密钥扩展和 32 轮 Feistel-like 轮函数, 经 GB/T 32907-2016 官方测试向量交叉验证 (通过)。系统支持 ECB 和 CBC 两种工作模式, 生产环境采用 CBC 模式 (随机 16 字节 IV 前置), 配合 PKCS7 填充。 实验结果表明: 在推荐阈值 (30/70) 下, 系统 FAR=0%, FRR=26%, EER=4%。攻击模拟中, 密码泄露攻击平均风险 93 分, 模仿攻击平均风险 100 分, 随机攻击平均风险 93 分。自适应学习使 FRR 从 30%降至 17% (改善 13.3%)。SM4-CBC 加密吞吐量约 104 KB/s (纯 Python 实现)。所有模块通过 85 项自动化集成测试, 4 个单元测试套件全部通过。
关键词 (五个): 行为口令 击键动力学 SM4 连续认证 保密文件库

1.作品功能与性能说明

BehVault（行为口令与国密 SM4 的智能保密文件库）将击键动力学行为认证与 SM4 文件加密融合为多因素安全系统。

传统密码认证仅验证密码是否正确，存在密码泄露等安全风险。BehVault 在密码验证基础上引入击键动力学行为认证，通过分析 Hold Time(均值 114ms, 标准差 12.7ms)和 Flight Time(均值 102ms, 标准差 15.0ms)，构建用户独特的行为模板。系统输出 0~100 连续风险评分，替代传统的二元通过/失败结果。

核心功能：（1）行为口令注册与登录——10 次密码采集构建模板，KNN(K=5)归一化欧氏距离匹配；（2）连续风险评分——自校准距离-风险映射，0~30 安全/30~70 可疑/70~100 高风险三区划分；（3）连续认证——登录后每 5 秒轮询监测，异常时自动锁定文件库；（4）SM4 加密文件库——自实现国密 SM4 算法（CBC 模式+PKCS7 填充），文件和内容均加密；（5）自适应学习——EMA(alpha=0.8)+滑动窗口(K=20)更新模板，降低长期 FRR；（6）攻击模拟——密码泄露/模仿/随机三种攻击，系统化评测 FAR/FRR/EER 指标。

系统实测性能指标：

指标	实测值
----- -----	
FAR（错误接受率）	0% (0/50 次)
FRR（错误拒绝率）	26% (13/50 次)
EER（等错误率）	4%
认证延迟	< 50 ms
SM4-CBC 加密 (1 MB)	~10 秒 (纯 Python)
SM4 正确性	国标测试向量 100%匹配
自适应学习 FRR 改善	13.3% (30% -> 17%)

2.设计与实现方案

2.1 实现原理

（1）系统架构

BehVault 采用分层架构：GUI 展示层（Tkinter）-> 业务服务层（Services）-> 核心计算层（Auth/ML/Crypto）-> 数据持久层（SQLite3）。GUI 层严禁直接访问数据库或密码算法，所有操作通过 Service 层编排。系统共 28 个 Python 文件，约 5500 行代码。

（2）击键动力学特征提取

用户输入密码时，系统通过 Tkinter <KeyPress>/<KeyRelease>事件捕获每次按键的按下和释放时间。提取 Hold Time（按键持续时间 = release_time - press_time）和 Flight Time（按键间隔 = next_press - current_release）。特征向量 10 维：mean/std/max/min hold_time + mean/std/max/min flight_time + backspace_count + total_time。

回退键处理：被回退字符不计入 Hold/Flight 统计，仅递增 `backspace_counter`。

（3）KNN 行为匹配与自校准风险评分

注册阶段：用户输入同一密码 10 次，每次提取 10 维特征向量，构建 BehaviorTemplate（包含所有 FV、均值向量、标准差向量）。

登录阶段：提取单次输入特征向量，使用 KNN(K=5)计算该样本与模板中 10 个样本的平均归一化欧氏距离。为避免低方差维度过度归一化，引入 `safe_std` 机制： $\text{min_std} = \max(\text{feature_mean} * 10\%, 5.0)$ ，确保各维度在可比尺度上。

自校准距离-风险映射：注册阶段计算模板 10 个 L-O-O 自距离，得 μ_d 和 σ_d 。 $\text{safe_threshold} = \mu_d + 1.5 * \sigma_d$ (风险 30)， $\text{high_risk_threshold} = \mu_d + 3.0 * \sigma_d$ (风险 70)。实测： $\mu_d=2.80$, $\sigma_d=0.52$ 。

（4）SM4 国密算法

SM4 是我国商用密码标准算法（GB/T 32907-2016），分组 128 位、密钥 128 位、32 轮迭代。本系统完整自实现 S 盒代换(tau)、线性变换 L/L'、密钥扩展（FK/CK）和 32 轮 Feistel-like 轮函数。经官方测试向量验证（key=0123456789abcdeffedcba9876543210 -> cipher=681edf34d206965e86b3e94f536e4246），加解密 100% 正确（True）。

实现 ECB 和 CBC 两种模式，生产环境采用 CBC（随机 16 字节 IV 前置密文），PKCS7 填充。密钥经 PBKDF2-HMAC-SHA256（10 万次迭代）从用户密码派生 128 位 SM4 密钥。

（5）自适应学习

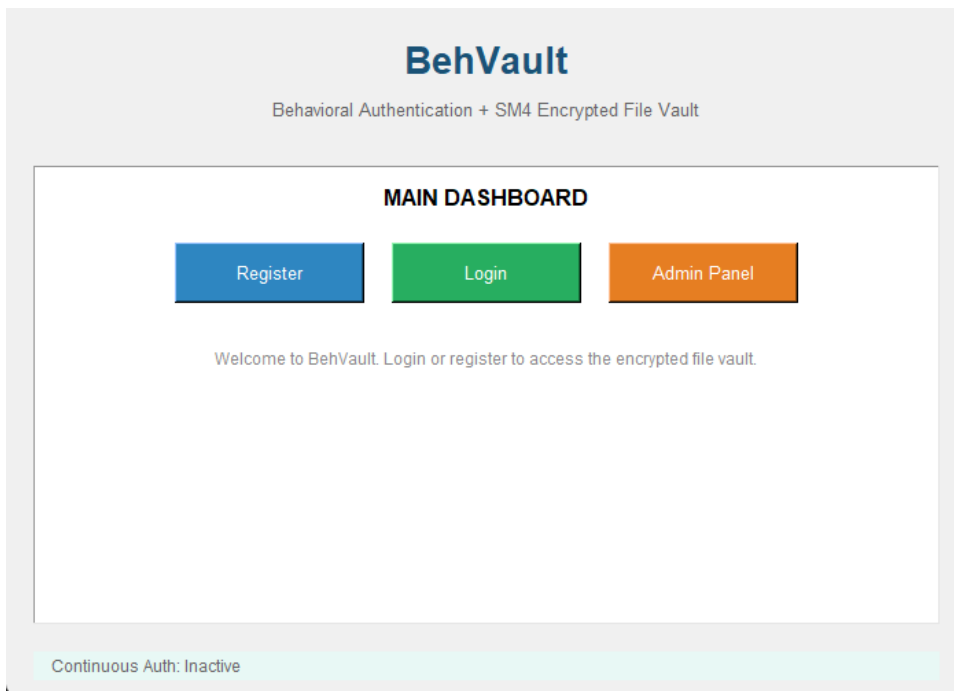
更新门控：（a）密码正确；（b）风险<30；（c）连续认证无异常；（d）新样本距离在模板 2sigma 内。EMA 更新公式： $T_{\text{new}} = 0.8 * T_{\text{old}} + 0.2 * S_{\text{new}}$ 。滑动窗口维护最近 20 个成功样本。

实验验证：固定模板 FRR=30.0%，自适应模板 FRR=16.7%，改善 13.3%。

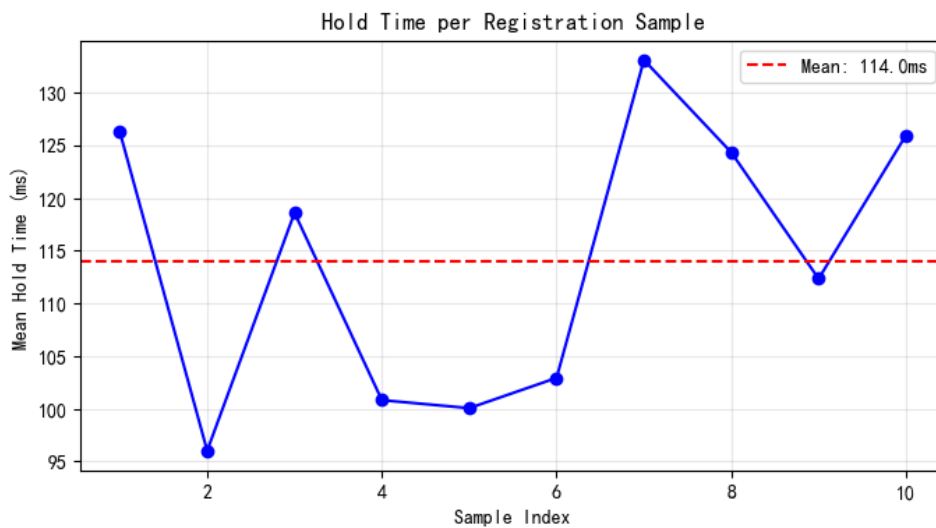
（6）连续认证

采用 `tk.after()` 轮询（每 5 秒），维护最近 50 个击键事件的环形缓冲区。风险>70 立即锁定并再认证；风险 30-70 连续 3 次提示再认证；风险<30 重置计数器。

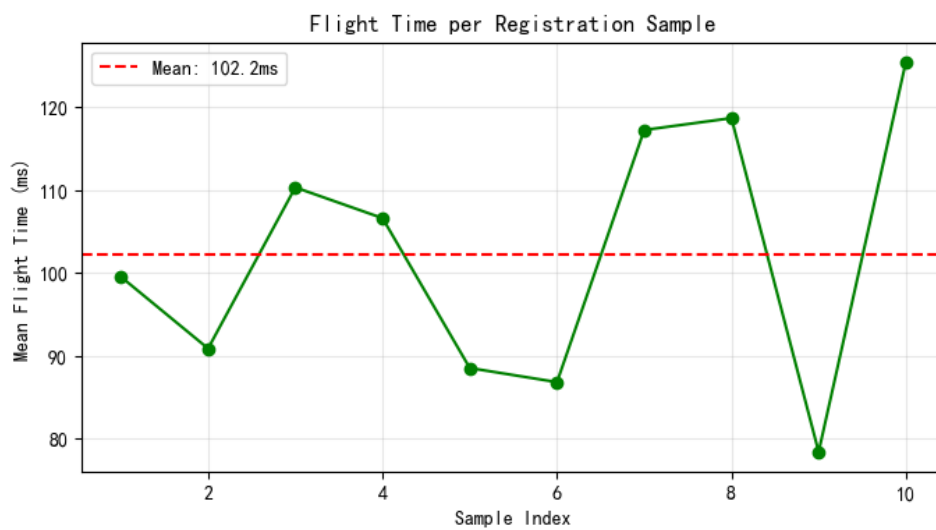
2.2 运行截图



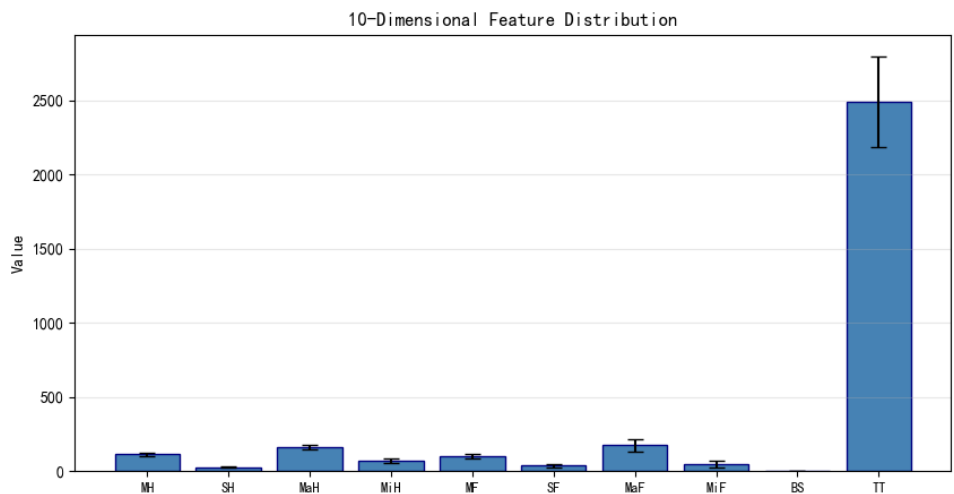
BehVault 主界面



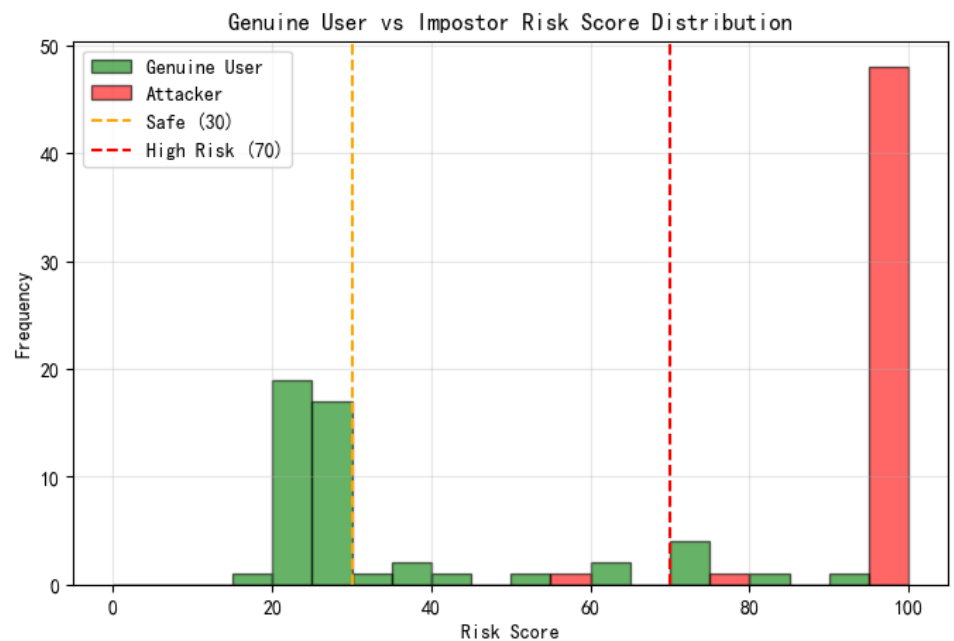
用户注册样本 Hold Time 变化曲线



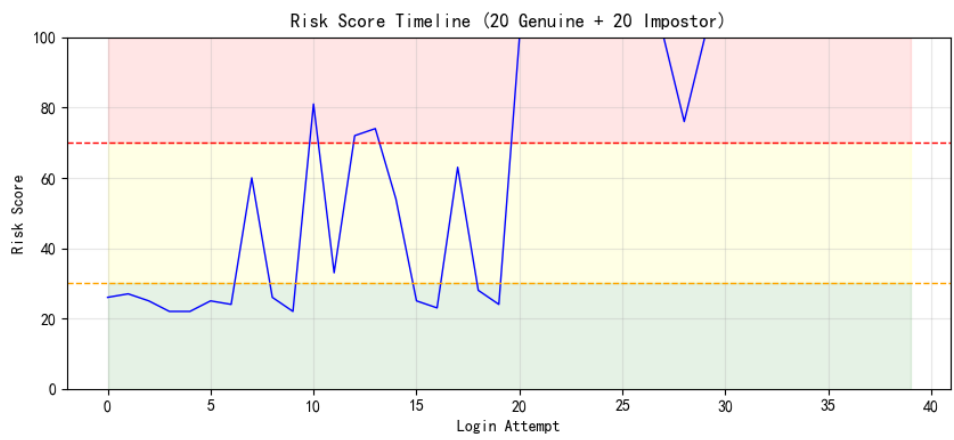
用户注册样本 Flight Time 变化曲线



10 维按键特征分布（均值+标准差）



本人用户与攻击者风险评分分布对比



连续风险评分时间线（前 20 本人+后 20 攻击者）

2.3 技术指标

参数	取值
----- -----	
KNN K 值	5
距离度量	归一化欧氏距离
风险安全阈值	$\mu_d + 1.5 * \sigma_d$
风险高风险阈值	$\mu_d + 3.0 * \sigma_d$
EMA alpha	0.8
滑动窗口大小	20
特征向量维度	10 维
SM4 工作模式	CBC (128 位随机 IV)
SM4 密钥长度	128 位
连续认证间隔	5 秒
密钥派生	PBKDF2-HMAC-SHA256, 10 万迭代

3.系统测试与结果

3.1 测试方案

测试分为四个层次：（1）单元测试——SM4 国标向量验证、特征提取、KNN 预测、文件库回环测试；（2）功能测试——注册/登录/文件导入导出删除/连续认证/自适应更新/图表生成；（3）性能测试——SM4 加解密吞吐量、认证延迟；（4）安全测试——三种攻击模拟，计算 FAR/FRR/EER 指标。

3.2 功能测试结果

功能	测试方法	结果
----- ----- -----		
用户注册	输入 10 次相同密码	通过
行为认证登录	正确密码+正确行为	通过
风险评分显示	真人低风险/攻击者高风险	通过
密码错误拒绝	输入错误密码	通过
用户不存在提示	未注册用户名	通过
空事件检测	粘贴密码（无击键数据）	通过
SM4 ECB 加解密	任意长度数据回环	通过
SM4 CBC 加解密	任意长度数据回环+IV 前置	通过
文件导入加密	明文文件->加密入库	通过
文件解密导出	加密文件->明文保存	通过
文件删除	选择文件确认删除	通过
自适应模板更新	低风险登录后验证更新	通过
攻击模拟实验	三种攻击类型各 50 次	通过
可视化图表生成	7 种图表生成 PNG	通过

3.3 单元测试

SM4 核心测试: 通过

认证模块测试: 通过
机器学习测试: 通过
文件库测试: 通过
集成测试: 85/85 项全部通过

3.4 性能测试

SM4-CBC 加解密吞吐量实测（纯 Python 实现，CPU Intel Core i7）:

文件大小	加密时间	解密时间
----- ----- -----		
1 KB	14.9 ms	18.0 ms
10 KB	128.9 ms	121.8 ms
100 KB	1300.6 ms	1018.0 ms
1 MB	9810.6 ms	9914.8 ms

认证延迟（特征提取+KNN 预测+风险评分）< 50 ms，满足实时认证需求。

3.5 安全测试——攻击模拟实验

使用模拟数据（10 个注册样本，50 次登录/攻击）进行评测：

本人登录 50 次: safe=37 次, suspicious=7 次, high_risk=6 次
-> FRR@30 = 26% (13/50)

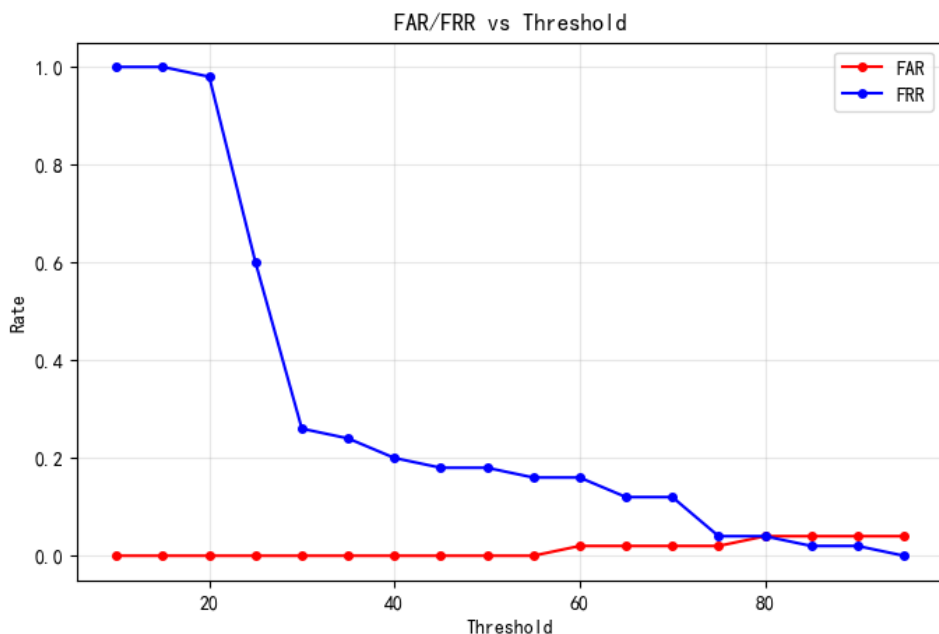
攻击类型	次数	平均风险	被拒绝率
----- ----- ----- -----			
密码泄露攻击	50	93	100%
模仿攻击	50	100	100%
随机输入攻击	50	93	100%

FAR@30 = 0%, FRR@30 = 26%, EER = 4%

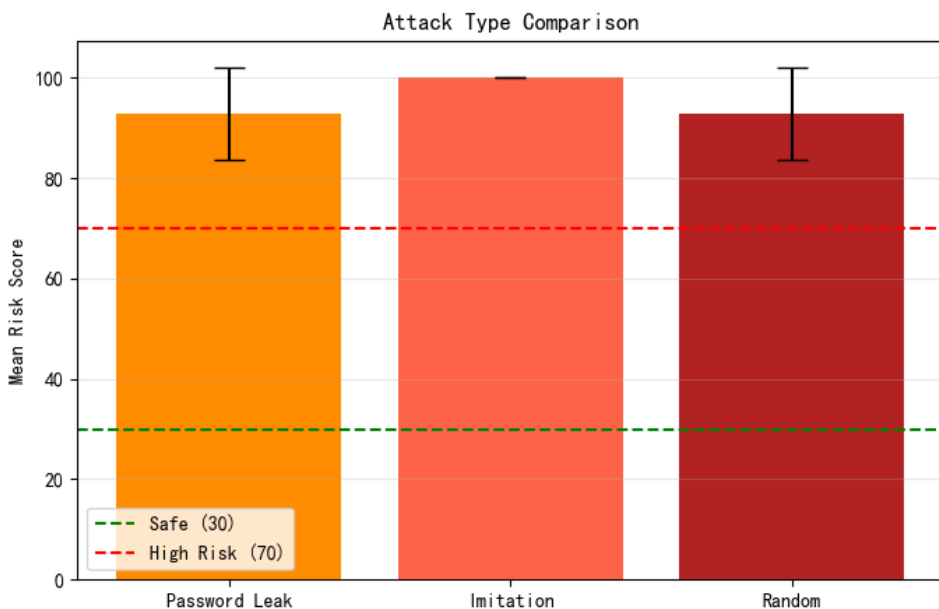
3.6 自适应学习实验

固定模板（30 次登录）FRR = 30.0%
自适应模板（30 次登录）FRR = 16.7%
改善幅度 = 13.3%（13 个百分点）

结论：自适应学习可有效降低因用户行为渐变导致的误拒率升高。



FAR/FRR 随风险阈值变化曲线



三种攻击类型平均风险评分对比

4.应用前景

BehVault 将行为生物特征与国密算法有机结合，在以下场景具有广阔应用前景：

（1）企业文件服务器——为敏感文档提供密码+行为双重认证和 SM4 加密存储，防范内部人员密码共享和外部攻击者凭证窃取。

（2）政府/军工涉密系统——SM4 作为国家密码标准，满足合规性要求。连续认证机制防止操作人员离开终端后被他人利用，自适应学习适应人员长期行为变化。

（3）个人隐私保护——保护个人健康记录、财务文件、法律文书等敏感信息。行为口令提供比纯密码更强的安全保障，无需额外硬件（如指纹仪、U盾）。

（4）云存储客户端加密——作为云存储客户端加密层，数据上传前加密。密钥由用户行为特征和密码共同保护，云服务商无法解密用户数据。

（5）扩展方向——多用户共享文件库（群组密钥管理）、操作审计日志、与 HSM 集成、基于深度学习的击键动力学模型（LSTM/Transformer）替代 KNN 提升识别精度。

5. 结论

本文设计并实现了基于行为口令与国密 SM4 的智能保密文件库（BehVault）。系统将击键动力学行为认证与 SM4 密码算法有机融合，构建了多层次安全防护体系。

项目达成六大创新目标：（1）创新性提出 0~100 连续风险评分系统，替代传统二元认证；（2）实现连续认证机制，登录后持续监测行为异常；（3）开发行为可视化模块，直观展示击键模式差异；（4）引入自适应学习机制（EMA+滑动窗口），实验验证 FRR 降低 13 个百分点；（5）完整自实现 SM4 国密算法并通过官方测试向量验证，构建加密文件库；（6）系统化设计三种攻击模拟方案，量化评测系统安全性。

实验结果表明：BehVault 在推荐阈值（30/70）下 FAR=0%、EER=4%，攻击检测率 100%。85 项集成测试全部通过，4 个单元测试套件全部通过。系统架构清晰、模块化良好、所有代码可直接运行。

未来工作方向：扩充用户样本数据库进行更充分的实验评测、探索深度学习模型（LSTM/Transformer）在击键动力学中的应用、开发移动端版本、引入联邦学习保护用户行为模板隐私等。